Revisión crítica: especificación frente al código

Sprints 1 a 3 · 27 de octubre de 2026 · `main` en `595e788` (CS-01 a CS-08, CS-20 y CS-32) · Regla 5 de CLAUDE.md

Resumen

Tres revisiones independientes leyeron el código frente a SPEC.md, las reglas AR, los ADR y la documentación: base de datos y seguridad; dominio y arquitectura del backend; y frontend, infraestructura y documentación. Cada hallazgo se comprobó en el código, y los más graves se verificaron otra vez antes de escribir este informe.

- **0 bloqueantes, 11 importantes y 21 menores.** Nada impide seguir con CS-09.
- **Antes de CS-09**, que empieza a guardar documentos de inquilinos, conviene cerrar el riesgo de que datos personales lleguen a los registros (I2) y los dos ajustes del borde (I3 e I4).
- **Seis decisiones son tuyas** (regla 2): RLS de los vouchers, cambio a `conjugal_split` con contratos, correo de privacidad, las dos políticas de privacidad, contenido de negocio en la especificación pública y la gracia de la prueba gratis.
- Lo demás lo resuelvo yo (regla 1) en PR pequeños, en el orden de la sección "Plan propuesto".

Ninguno de los hallazgos es explotable hoy: no hay nada desplegado ni datos reales.

Hallazgos importantes

Id	Hallazgo	Corrección	Cuándo
I1	**Deuda.** El inicio de sesión espera hasta 30 s dentro de la transacción, con una conexión del pool y la fila del límite por IP bloqueadas. El envío SMTP de la verificación y la recuperación también ocurre dentro de la transacción. Pocas peticiones lentas pueden agotar el pool, y el tiempo de respuesta de la recuperación delata si la cuenta existe.	Registrar los intentos en una transacción corta y responder 429 con `Retry-After` en vez de esperar en el servidor. Fijar `idle_in_transaction_session_timeout` y `lock_timeout`. Igualar el tiempo de la recuperación.	Antes de la beta regla 1
I2	**Hueco (regla 8).** Datos personales pueden llegar a los registros: • el motor no usa `hide_parameters`; • la API no tiene un manejador global de errores; • PostgreSQL registra el DETAIL de las violaciones de restricciones, con los valores; • no existe el procesador de structlog que pide el ADR-0007.	`hide_parameters=True`, un manejador que registre solo el tipo de excepción, `log_error_verbosity=terse`, el procesador de structlog y un test que fuerce una violación y busque el dato en los registros.	Antes de CS-09 regla 1

I3	**Hueco.** Caddy registra sus errores 5xx (por ejemplo, un 502 durante un despliegue) con IP, URI y cabeceras, incluida `X-Tenant-Token`. Contradice SPEC ("sin registrar /i ni consultas") y la política de privacidad.	Filtro de registro que quite IP, URI y cabeceras, o excluir `http.log.error`. Test de despliegue que fuerce un 502 y revise el registro.	Antes de CS-18 regla 1
I4	**Inconsistencia.** `/legal/*` muestra el RUC y el domicilio del responsable, pero no lleva `noindex`.	Agregar `/legal` al matcher y al test del borde. En SPEC, decir "domicilio" en vez de "datos del negocio", porque `/` y la calculadora deben seguir indexables.	Ahora regla 1
I5	**Inconsistencia.** Con las políticas y claves foráneas actuales, el inquilino no puede subir un voucher. La política de `files` en contexto `tenant` exige una fila de `voucher_submissions` que apunte al archivo, y esa fila exige antes el archivo (clave foránea no diferible). La reutilización por hash también choca con archivos de otros contratos.	Requiere una migración. Opciones: clave foránea diferible e insertar primero la solicitud; deduplicar por contrato; o una quinta función `SECURITY DEFINER`, que cambia AR-19.	Antes de CS-19 regla 2
I6	**Hueco.** Un inmueble puede pasar a `conjugal_split` teniendo contratos activos, y esos contratos seguirían entrando a las declaraciones.	Recomendado: impedir el cambio de titularidad hacia o desde `conjugal_split` mientras haya contratos activos, con el puerto `ActiveLeases` que ya existe. Alternativa: derivar el tratamiento al leer.	En CS-09 regla 2
I7	**Hueco.** Los tests del catálogo (AR-13 y AR-14) solo miran tablas. Una vista de `casero_owner` concedida a `casero_app` expondría todas las cuentas y pasaría los tests. Tampoco se revisa la pertenencia entre roles.	Inspeccionar también vistas, vistas materializadas y secuencias. Exigir `security_invoker` o prohibir vistas, y afirmar que no hay pertenencias entre los roles `casero_*`.	Antes de CS-12 regla 1
I8	**Deuda.** Varios tests de arquitectura detectan menos de lo que su regla promete: • AR-06 no ve alias de `datetime` ni `time.time()`; • AR-07 no ve `BackgroundTasks`; • AR-08 no ve la división real (`/`); • AR-09 solo revisa literales en `tax/domain`; • AR-16 y AR-18 solo prueban lecturas, no `WITH CHECK`; • AR-20 no exige CSRF en las rutas que escriben.	Cerrar cada hueco con su meta-test.	Antes de CS-12 regla 1

I9	**Hueco.** Los textos legales tienen marcadores sin fuente: correo de privacidad, correo de atención, fecha de publicación, número de expediente y el aviso de borrador. Se mostrarían tal cual, y ningún test lo impide.	Decidir de dónde sale el correo de privacidad: una variable nueva servida por `/api/public/business`, o el correo de reclamos. Luego, un test que falle si queda un marcador `[…]` o el aviso de borrador.	Antes de publicar la landing regla 2
I10	**Hueco.** El procedimiento de vuelta atrás (`docs/ops/server.md`) cambia `IMAGE_TAG`. Si entre las dos versiones hubo una migración, `migrate` falla y la app no arranca.	Documentar que solo sirve sin migraciones intermedias; si las hay, corregir hacia adelante o restaurar el respaldo.	CS-26 regla 1
I11	**Hueco.** CS-12 necesita el umbral de bancarización, pero `ledger` está debajo de `tax` y no puede importarlo.	Puerto `CashThresholds` en `ledger.application`, implementado con `SqlTaxRuleBook` y cableado en `api.py`. Agregarlo a los casos conocidos de ARCHITECTURE_RULES.md.	En CS-12 regla 1

Hallazgos menores

Datos y seguridad

- `purge_account` no comprueba que la fase de almacenamiento se ejecutó. Si no se encolaron los archivos, borra sus filas y deja objetos huérfanos (CS-25).
- La promesa de que el panel interno no ve filas aunque se le otorgue un permiso por error no se prueba con `app.account_id` fijado. Limitar las políticas a `casero_app` y `casero_worker` y extender AR-17 (CS-24).
- Las funciones `SECURITY DEFINER` no terminan su `search_path` en `pg_temp`. Es seguro solo porque TEMP está revocado, y ningún test lo afirma (seguimiento de CS-03).
- El hash de la IP usa una clave permanente con la fecha, no una sal aleatoria que rote cada día como dicen SPEC, el ADR-0004 y la política de privacidad. Además, `pg_dump` incluiría esa tabla en los respaldos. Lo corrijo para que cumpla lo escrito (CS-26).

Backend

- `docs/ops/tax-config.md` dice que el método de redondeo se cambia en el YAML, pero solo existe `half_up_sol` en el código y en la base. Si el contador pide redondear solo el tributo, hacen falta código, migración y ADR antes de CS-21.
- La prueba gratis termina con 7 días de gracia extra. Está así a propósito y probado, pero SPEC no lo dice. Lo decides en CS-23.
- Nadie borra la lista de espera a los 12 meses: ninguna historia es dueña de esa tarea. La asigno a CS-25.
- Deuda en el worker:
  - todas las tareas corren en cada vuelta, sin horario de Lima;
  - el SQL de `job_runs` vive en `admin`;
  - el worker no detecta que perdió el candado ni maneja SIGTERM.

  Se ordena antes de CS-11.
- No hay un tipo de período compartido, y `RucGroup` está definido dos veces. Lo resuelvo en CS-09 a CS-11.

- La construcción de entradas de auditoría está repetida entre módulos. Lo resuelvo en CS-09 a CS-11.
- `api.py` ya tiene más de 500 líneas de cableado. El cableado interno de cada módulo puede vivir en su paquete `api`, dejando en `api.py` solo los puertos entre módulos.

Frontend, infraestructura y documentación

- La página legal ignora la versión de la URL, así que tras la versión 0.2 los enlaces de aceptaciones antiguas mostrarían el texto nuevo (CS-25).
- Hay dos políticas de privacidad vigentes: el pie y la lista de espera enlazan la corta, y el registro, la completa. El pie no enlaza los términos. Decisión tuya, en CS-25.
- Las páginas de "no encontrado" y de error del router salen en inglés. Quien tenga la app abierta durante un despliegue las verá (CS-09).
- Hay dos límites de 5 MB distintos en Caddy (5,000,000 y 5,242,880 bytes) (CS-19).
- La CSP bloqueará a Sentry en el navegador; hará falta un túnel por `/api` (CS-26).
- Ninguna historia es dueña de la PWA instalable (manifiesto, íconos y service worker). La agrego a CS-18.
- El árbol del repositorio en SPEC está desactualizado: `web/src/app`, `infra/edge`, `backend/scripts`, los tests de despliegue y `make seed`.
- SPEC, que es pública, contiene condiciones de preventa y metas de activación, y la landing repite precios y límites que viven en `plans`. Decisión tuya.
- En los tests del frontend, las consultas fallidas se reintentan y una ruta sin simular responde 404 en silencio. Desactivo los reintentos y hago fallar las rutas sin simular.
- El criterio de `List-Unsubscribe` real de CS-04 no se puede comprobar hasta que existan correos programados. Lo muevo a CS-34.

Lo que está sólido

- **Aislamiento:**
  - todas las tablas de cuenta tienen `UNIQUE (account_id, id)` y claves foráneas compuestas;
  - RLS forzada que falla cerrada;
  - el contexto `tenant` es una política restrictiva;
  - el test de catálogo compara permisos por tabla y columna con la tabla de roles de SPEC, y AR-18 siembra cada tabla para no pasar en vacío.
- **Dinero e impuesto:**
  - solo enteros;
  - el ejemplo 450.50 + 100.50 → base 551, tributo 28 está probado de punta a punta;
  - el cargador de YAML exige la fuente `https` y valida que cada período tenga todos los grupos;
  - el dígito verificador del RUC está probado con RUC reales.
- **Sesiones:**
  - tokens guardados como hash y rotados al iniciar sesión;
  - un correo desconocido recibe una verificación simulada;
  - Argon2 corre fuera del event loop;
  - los tokens viajan en el fragmento de la URL;
  - Uvicorn no registra peticiones.

- **CI:**
  - las acciones están fijadas por SHA;
  - auditoría de dependencias y escaneo de secretos en todo el historial;
  - detección de cambios en el contrato OpenAPI;
  - prueba del borde con el Caddyfile de producción;
  - un meta-test por cada contrato de import-linter.
- **Frontend:**
  - TypeScript estricto con `noUncheckedIndexedAccess`;
  - letra de 16 px y controles de 44 px;
  - errores enlazados a sus campos;
  - ninguna tasa ni monto de SUNAT escrito en la web.

Plan propuesto

Cuándo	Qué
Antes de CS-09	PR de endurecimiento: I2 (registros sin datos personales), I3 (registro de errores de Caddy), I4 (`noindex` en `/legal`). En un PR de documentación: SPEC (árbol, `noindex`), `tax-config.md`, el criterio de CS-04 movido a CS-34, la PWA en CS-18 y la purga de la lista de espera en CS-25.
Durante CS-09	I6 según tu decisión; páginas de error en español; CSRF exigido por AR-20; tests del frontend más estrictos; tipo de período compartido.
Antes de CS-11 y CS-12	I7 e I8 (tests de arquitectura y catálogo); orden del worker; I11.
Antes de la beta	I1 (inicio de sesión y correo fuera de la transacción); sal diaria del límite de peticiones; `search_path` con `pg_temp`; I10.
En su historia	I5 (CS-19), I9 (puerta de la landing y CS-25), los menores de CS-23, CS-24, CS-25 y CS-26.

Decisiones para Alessandro (regla 2)

- **I6, cambio a `conjugal_split` con contratos activos:** recomiendo impedirlo hasta que terminen los contratos. Se necesita en CS-09.
- **I5, RLS de los vouchers:** recomiendo clave foránea diferible, insertar primero la solicitud y deduplicar por contrato, sin una función `SECURITY DEFINER` nueva. Se necesita antes de CS-19.
- **I9, correo de privacidad:** recomiendo una variable propia (`CASERO_PRIVACY_INBOX`) servida como los demás datos del negocio. Puede ser la misma cuenta de Gmail.
- **Dos políticas de privacidad:** recomiendo dejar solo la completa cuando el abogado la revise.
- **Contenido de negocio en la SPEC pública:** recomiendo mover al repositorio privado las condiciones de preventa y las metas de activación, y dejar en SPEC solo las puertas técnicas.
- **Gracia de la prueba gratis:** decidir en CS-23 si la prueba tiene los 7 días de gracia.